

Mobil Uygulama Güvenliđi

a) Ekran görüntüsü ve ekran kaydı

Neden önemlidir? Kredi kartı bilgileri veya hesap bakiyesi gibi hassas verilerin, cihazdaki kötü amaçlı yazılımlar (ekran okuyucular) veya kullanıcının yanındaki kişiler tarafından kaydedilip çalınmasını engellemek için kritik bir güvenlik adımıdır.

Güvenlik Mekanizmaları: Android tarafında ilgili sayfanın koduna FLAG_SECURE bayrağı eklenerek ekran kaydının simsiyah çıkması sağlanır. iOS tarafında ise isCaptured değişkeni ile ekran kaydı tespit edilip arayüzün üzerine siyah bir katman (blur/bulanıklık) atılır.

b) Overlay (Gölgeleme/Katman) saldırıları

Nasıl gerçekleşir? Saldırgan, "diğer uygulamaların üzerinde göster" izni almış zararlı bir uygulama aracılığıyla, asıl uygulamanın (örneğin bankanın) tam üstüne şeffaf bir katman çizer.

Örnek: Arkada bankacılık uygulamasının "100.000 TL Gönder" butonu açıkken, üstteki şeffaf katmana tam o butonun hizasında "Hediyeni Al" butonu yerleştirilir. Kullanıcı oyundaki hediyeı aldığını sanarak ekrana dokunur ancak tıklama arkaya geçer ve havaleı onaylamış olur (Tapjacking).

c) Root / Jailbreak

Neden daha risklidir? İşletim sisteminin temel güvenlik kalkanı (sandbox mimarisi) kırıldığı için, uygulamaların birbirinin özel alanına ve hafızasına erişmesinin önündeki engeller kalkar.

Örnek: Saldırgan root yetkisi olan basit bir dosya yöneticisi kullanarak uygulamanın gizli klasörüne sızabilir ve oradaki yerel veritabanı (SQLite) dosyasını kopyalayarak içindeki tüm şifreleri veya mesajları okuyabilir.

d) SQLite ve şifreleme

Düz metin (plain text) riski: Normal SQLite dosyaları şifresizdir. Cihaz çalınırsa veya root'lanıp dosya kopyalanırsa, veritabanı herhangi bir programla açıldığında tüm kullanıcı verileri kabak gibi okunabilir.

SQLCipher kullanıldığında değişen şey: Veritabanındaki tüm bilgiler diske yazılmadan önce 256-bit AES ile şifrelenir. Dosya çalınsa bile, doğru kriptografik anahtar (key) olmadan içindeki veriler tamamen anlamsız bir karakter çorbası olarak görünür.

e) Access Token ve Refresh Token

Farkı: Access Token, uygulamayı kullanırken sunucuya "ben kimim" demek için yolladığımız asıl anahtardır. Refresh Token ise süresi biten Access Token'ı yenilemek için kullandığımız yedek/uzun ömürlü anahtardır.

Access Token neden kısa süreli tutulabilir? İnternet trafiğinde sürekli taşındığı için çalınma riski yüksektir. Çalınsa bile hacker'ın elinde sadece 15-20 dakika geçerli kalsın ve hemen çöp olsun diye kısa süreli tutulur.

Refresh Token neden daha güvenli yerde saklanmalıdır? Çünkü bu token ile sürekli yeni Access Token'lar üretilir. Adeta "anahtar üreten makine" gibidir, bu yüzden cihazın kırılması zor donanımsal kasalarında (KeyStore vb.) saklanmalıdır.

Çıkış yapıldığında neden Refresh Token iptal edilir? Kullanıcı bilinçli olarak oturumu kapattıktan sonra, eğer biri bu token'ı ele geçirirse arka planda gizlice yeni bir Access Token alıp hesaba tekrar sızamasın diye sunucu tarafında tamamen geçersiz kılınmalıdır.